



ANEXO 1.1 — POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN

CAMPO	DETALLE
Empresa Proveedorora	VyKCore Automation S.R.L.
Producto/Servicio	VyKOne ERP — Plataforma de Facturación Electrónica (e-CF) conforme DGII
Código del documento	POL-SEG-001
Versión	1.0
Fecha de emisión	31 de julio de 2026
Clasificación	Pública
Responsable	Esmerlin Paniagua Martinez — Gerente

1. Objetivo

Establecer los controles de seguridad de la información que VyKCore Automation S.R.L. implementa en su plataforma VyKOne ERP para garantizar la confidencialidad, integridad y disponibilidad de los datos de los contribuyentes que utilizan el servicio de Facturación Electrónica (e-CF), así como el cumplimiento de la normativa de la Dirección General de Impuestos Internos (DGII).

2. Alcance

Esta política aplica a todos los colaboradores, sistemas, aplicaciones, datos y procesos que forman parte de la operación del servicio de facturación electrónica, incluyendo los ambientes de sandbox y producción, y la plataforma multi-tenant alojada en Firebase/Cloud.

3. Marco Normativo y Referencias

- Ley núm. 172-13 sobre Protección de Datos Personales.
- Normas DGII para Comprobantes Fiscales Electrónicos (e-CF).
- Norma ISO/IEC 27002 como referencia de buenas prácticas (adoptada parcialmente).
- Documentación interna de la organización sobre control de acceso y aislamiento de datos.

4. Controles de Seguridad Implementados

4.1 Control de Acceso y Autenticación

- Autenticación mediante **Firebase Authentication** (proveedor de identidad gestionado), con verificación de credenciales por API.
- **Autenticación en dos pasos (2FA/TOTP)** habilitada, con 8 códigos de respaldo almacenados con hash SHA-256.
- **Sesión única activa por usuario:** al iniciar sesión desde otro dispositivo se invalida la sesión anterior, registrando IP, agente de usuario y última actividad.
- Cookies con atributos `HttpOnly`, `SameSite=Lax` y `Secure` en producción.
- Bloqueo por intentos fallidos: **5 intentos → bloqueo de 15 minutos**.

- Registro público deshabilitado; las cuentas se crean mediante personal autorizado.

4.2 Autorización (RBAC) y Segregación de Funciones

- Control de acceso basado en **roles y permisos** (28 permisos granulares), con perfiles predefinidos: Administrador, Vendedor, Contador y Consulta.
- Permiso de **propietario** (`owner`) con control total del entorno.
- **Matriz de Segregación de Funciones (SoD)** con 5 pares de conflictos (ej. emitir vs. anular facturas; gestionar RRHH vs. aprobar nómina), con registro de acciones conflictivas.
- Activación de módulos por permiso.

4.3 Cifrado y Protección de Datos en Tránsito y en Reposo

- **En tránsito:** TLS/HTTPS en todos los puntos de acceso, HSTS en producción; comunicación con la DGII mediante **mTLS con certificado de cliente**.
- **Cabeceras de seguridad** en todas las respuestas: `X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff`, `Referrer-Policy`, `Permissions-Policy`, CSP con `frame-ancestors 'none'`, supresión de cabecera de servidor.
- **En reposo:** cifrado de campos sensibles (secretos 2FA, credenciales de pasarelas, licencias) mediante **Fernet**; claves de API y códigos de respaldo con **hash SHA-256**.
- **Firma digital XML** (XMLDSig RSA-SHA256, W3C enveloped) para los comprobantes e-CF.

4.4 Protección contra Amenazas Comunes

- **CSRF:** protección global en toda la aplicación.
- **CORS:** orígenes restringidos por configuración de entorno.
- **Rate limiting:** límite global (2000/día, 500/hora, 200/min en producción) y límites específicos en login, 2FA y restablecimiento de contraseña.
- **Validación de subidas:** extensión + MIME + tamaño máximo 16 MB, nombre de archivo saneado.
- **XSS:** escape automático de plantillas y CSP.

4.5 Aislamiento Multi-Tenant

- Cada empresa (tenant) almacena sus datos en colecciones segmentadas y aisladas.
- Separación estricta de **ambiente sandbox vs. producción** mediante almacenes de datos independientes, con cambio protegido por permiso de administración.
- Verificación de pertenencia del usuario a la empresa en cada solicitud.

4.6 Seguridad de la Información para la Emisión e-CF

- Validación de RNC/cédula por algoritmo de dígito verificador.
- Certificados de firma digital PKCS#12 validados al cargar.
- Registro en bitácora de toda emisión (aceptación o rechazo ante la DGII, con TrackID y modo de emisión).

5. Gestión de Incidentes y Bitácora

- **Bitácora de eventos centralizada** con acciones canónicas CREATE/UPDATE/DELETE/VIEW/ LOGIN/LOGOUT/EXPORT, incluyendo IP, usuario, antes/después y ambiente. Ver documento **Anexo 7 — Bitácora de Eventos**.
- Registro de intentos de inicio de sesión (exitosos y fallidos) y cierre de sesión.

6. Responsabilidades y Revisión

- El **Gerente** es responsable de la implementación y cumplimiento de esta política.
- El documento se revisa al menos **anualmente** o ante cambios significativos de la plataforma o la normativa DGII aplicable.

7. Sanciones por Incumplimiento

El incumplimiento de esta política podrá dar lugar a medidas disciplinarias conforme a la normativa interna, y a las sanciones establecidas en la normativa vigente de la DGII.

8. Control de Versiones

VERSIÓN	FECHA	DESCRIPCIÓN DEL CAMBIO	ELABORADO POR	APROBADO POR
1.0	2026-07-31	Emisión inicial para requerimiento DGII	Esmerlin Paniagua Martinez	Esmerlin Paniagua Martinez

9. Aprobación y Firma

	NOMBRE	CARGO	FIRMA	FECHA
Elaborado por	Esmerlin Paniagua Martinez	Gerente		2026-07-31
Aprobado por	Esmerlin Paniagua Martinez	Gerente		2026-07-31